

Gati-Tech AMS

Quality & Security Testing Report

Project	Gati-Tech Asset Management System
Platform	Next.js 15 Static Export · GitHub Pages
Version	v1.0.0 (branch: claude/gati-tech-asset-management)
Report Date	10 June 2026
Prepared By	QA Engineering / Claude Code
Classification	Internal / Confidential
Covers	VAPT · Unit Testing · Regression Testing

Table of Contents

1. Vulnerability Assessment & Penetration Testing (VAPT)

1. Scope & Methodology
2. Findings & Risk Register
3. Security Checklist (OWASP Top 10)
4. Remediation Tracker

2. Unit Testing

1. Scope & Coverage Targets
2. Test Case Register
3. Results Summary

3. Regression Testing

1. Scope & Trigger Conditions
2. Test Suites
3. Regression Matrix
4. Execution Results

4. Sign-off

1. Vulnerability Assessment & Penetration Testing (VAPT)

1.1 Scope & Methodology

Item	Detail
Assessment Type	White-box static analysis + manual review (no live exploitation on production)
Target URL	https://yadukrishnan117.github.io/studio/
Source Repository	github.com/Yadukrishnan117/studio
Frameworks	Next.js 15, React 19, Mongoose 8, Firebase (config only)
Standards Applied	OWASP Top 10 (2021), OWASP WSTG v4.2, CWE/CVE taxonomy
Tools Used	Manual code review, regex analysis, dependency audit (npm audit)
Tester	Internal Security Review
Test Period	10 June 2026

1.2 Findings & Risk Register

#	Title	Category (OWASP)	Severity	CWE	Status
V-001	No authentication on any API route	A01 Broken Access Control	Critical	CWE-306	Open
V-002	Plaintext demo password in UI + any password accepted	A07 Identification & Auth Failures	Critical	CWE-521	Open
V-003	Unvalidated <search> param passed to MongoDB \$regex (ReDoS)	A03 Injection	High	CWE-730	Open
V-004	Unbounded limit param		High	CWE-770	Open

	allows full-collection dump	A01 Broken Access Control			
V-005	Mass assignment — request body spread directly into Mongoose create()	A03 Injection / A04 Insecure Design	High	CWE-915	Open
V-006	Hardcoded MongoDB fallback URI disables env-variable guard	A02 Cryptographic / Config Failures	Medium	CWE-547	Open
V-007	No Content-Security-Policy (CSP) header	A05 Security Misconfiguration	Medium	CWE-1021	Open
V-008	localStorage auth token (gati_auth) is not signed/encrypted	A02 Cryptographic Failures	Medium	CWE-311	Open
V-009	API routes in static export — silently 404 in production	A04 Insecure Design	Medium	CWE-670	Noted
V-010	No dashboard auth guard (before fix)	A01 Broken Access Control	High	CWE-306	Fixed

1.2.1 Detailed Finding Notes

V-001 — No authentication on API routes

All `src/app/api/*/route.ts` handlers execute unconditionally. No session token, JWT, or middleware validation is performed. An unauthenticated caller can enumerate all assets, vehicles, customers and maintenance records via HTTP GET, and create/modify records via POST.

Remediation: Implement NextAuth.js or a signed JWT middleware that validates a Bearer token on every API route. Alternatively, move all data to a backend-for-frontent pattern where the BFF handles auth before proxying.

V-003 — MongoDB \$regex injection / ReDoS

In `src/app/api/assets/route.ts` (line 21), `src/app/api/vehicles/route.ts` (line 21), and `src/app/api/maintenance/route.ts` (line 19), the search query parameter is interpolated directly into a `$regex` operator without escaping regex metacharacters.

Remediation: Escape the search string with a regex-escape utility (e.g. `search.replace(/[.*+?^${}()|[\]\]/g, '\\$&')`) before use in `$regex`. Consider MongoDB text indexes instead of `$regex` for full-text search.

V-005 — Mass assignment

POST body is spread wholesale (`{ ...body, assetId }`) into Mongoose `create()`. An attacker can set internal schema fields, override status, or inject unexpected properties.

Remediation: Use an allowlist: destructure only known fields from `body` before passing to Mongoose, or use a validation library (Zod, Joi).

1.3 OWASP Top 10 Checklist

#	Category	Checked?	Result
A01	Broken Access Control	✓	Fail — V-001, V-004, V-010
A02	Cryptographic Failures	✓	Partial — V-006, V-008
A03	Injection	✓	Fail — V-003, V-005
A04	Insecure Design	✓	Partial — V-009
A05	Security Misconfiguration	✓	Partial — V-007, missing HSTS
A06	Vulnerable & Outdated Components	✓	Pass — No critical npm advisories
A07	Identification & Auth Failures	✓	Fail — V-002
A08	Software & Data Integrity Failures	✓	Pass — No CI supply-chain issues found
A09	Security Logging & Monitoring Failures	✓	Partial — No audit log for data access
A10	Server-Side Request Forgery (SSRF)	✓	Pass — No user-controlled URL fetch found

1.4 Remediation Tracker

ID	Severity	Action Required	Owner	Target Date	Verified By
V-001	Critical	Add JWT middleware to all API routes			
V-002	Critical	Implement real credential validation; remove demo password hint from UI			
V-003	High	Escape regex metacharacters in search param			
V-004	High	Cap limit param to max 100			
V-005	High	Allowlist fields before Mongoose create()			
V-006	Medium	Remove hardcoded fallback URI; throw on missing env var			
V-007	Medium	Add CSP, X-Frame-Options, X-Content-Type-Options headers			
V-008	Medium	Sign localStorage token or replace with httpOnly cookie session			

2. Unit Testing

2.1 Scope & Coverage Targets

Module	Target Coverage	Priority
Authentication logic (login, logout, auth guard)	100%	P1
API route handlers (assets, vehicles, maintenance, parts, customers, vendors)	90%	P1
Mock data utilities / lib/mock-data.ts	80%	P2
UI components (TopNav, Sidebar, Dashboard cards)	70%	P2
Filter / search logic on all dashboard pages	85%	P1
Form validation (Add Asset, Add User, Add Vehicle)	90%	P1
Notification read/unread state management	100%	P2

Testing Framework: Jest + React Testing Library (RTL). Run with `npm test -- --coverage`. Minimum passing threshold: 80% lines.

2.2 Test Case Register

UT-AUTH — Authentication

ID	Test Case	Input	Expected Output	Status
UT-AUTH-001	Valid login stores auth token	email=admin@gatitech.in, password=any	localStorage gati_auth is written; redirect to / dashboard	Pending
UT-AUTH-002	Empty email blocks login	email="", password='pass'	Error message shown; no redirect	Pending
UT-AUTH-003	Empty password blocks login	email='a@b.com', password=""	Error message shown; no redirect	Pending
UT-AUTH-004	Logout clears token and redirects	gati_auth in localStorage; click Logout	gati_auth removed; redirected to /login	Pending

UT-AUTH-005	Dashboard guard redirects unauthenticated	No gati_auth; navigate to /dashboard	Redirected to /login	Pending
UT-AUTH-006	Dashboard guard allows authenticated user	gati_auth set; navigate to /dashboard	Dashboard renders	Pending

UT-ASSET — Asset Management

ID	Test Case	Input	Expected Output	Status
UT-ASSET-001	Asset list renders all mock assets	initialAssets (15 items)	15 rows in table	Pending
UT-ASSET-002	Search filter narrows results	search='hydraulic'	Only matching rows shown	Pending
UT-ASSET-003	Status filter works	statusFilter='active'	Only active assets shown	Pending
UT-ASSET-004	Add Asset with valid data appends row	name='Lift', category='equipment', branch='Main Branch'	Row count +1; new asset at top	Pending
UT-ASSET-005	Add Asset without required fields does nothing	name="", category="", branch=""	No new row; modal stays open	Pending
UT-ASSET-006	Delete asset removes row	Confirm dialog → OK	Row count -1	Pending
UT-ASSET-007	Delete asset cancelled keeps row	Confirm dialog → Cancel	Row count unchanged	Pending
UT-ASSET-008	View Details opens modal with correct data	Click row or Eye icon	Modal shows asset name and ID	Pending

UT-NOTIF — Notifications

ID	Test Case	Input	Expected Output	Status
UT-NOTIF-001	Unread badge shows correct count	2 unread alerts in mock data	Badge shows '2'	Pending
UT-NOTIF-002	Clicking notification marks it read	Click alert with id='a1'	Badge count -1; dot indicator gone	Pending
UT-NOTIF-003	Mark all read clears badge	Click 'Mark all read'	Badge disappears; all items show read styling	Pending
UT-NOTIF-004	Read state persists across re-renders	Mark read; unmount; remount	Badge still shows updated count	Pending

UT-API — API Route Handlers

ID	Test Case	Input	Expected Output	Status
UT-API-001	GET /api/assets returns 200 with array	No params	JSON array, status 200	Pending
UT-API-002	GET /api/assets? search=lift returns filtered results	search='lift'	Only matching records	Pending
UT-API-003	POST /api/assets with valid body creates record	Valid asset JSON	Status 201, created record returned	Pending
UT-API-004	POST /api/assets with missing required fields returns 400	Missing name	Status 400 with error message	Pending
UT-API-005	GET /api/health returns 200	No params	{ status: 'ok' }	Pending

UT-SETTINGS — Settings Page

ID	Test Case	Input	Expected Output	Status
UT-SET-001	User Active toggle changes state	Toggle switch for user u2	Switch reflects new value; user.isActive updated	Pending
UT-SET-002	Delete user removes from list	Click delete for u3; confirm	User row removed from table	Pending
			User list +1 row	Pending

UT-SET-003	Add User with valid data appends row	name, email, role, branch all set		
UT-SET-004	Add User with missing fields is blocked	name set, email empty	No new row added	Pending

2.3 Results Summary

Suite	Total	Passed	Failed	Skipped	Coverage
UT-AUTH	6	—	—	6	—
UT-ASSET	8	—	—	8	—
UT-NOTIF	4	—	—	4	—
UT-API	5	—	—	5	—
UT-SETTINGS	4	—	—	4	—
Total	27	0	0	27	N/A — Tests not yet written

Action Required: Unit tests have not yet been authored. Install Jest + RTL (npm install --save-dev jest @testing-library/react @testing-library/user-event jest-environment-jsdom) and create test files under src/__tests__/.

3. Regression Testing

3.1 Scope & Trigger Conditions

Regression tests are executed whenever one of the following occurs:

- A pull request is merged to main
- A dependency is upgraded (package.json changes)
- A bug fix is applied to a previously passing area
- The deployment workflow or Next.js config is modified

Trigger	Regression Scope	Automation
PR merge to main	Full suite (all modules)	GitHub Actions CI
Auth change	UT-AUTH + RT-AUTH	Manual + CI
UI component change	Affected page + smoke tests	Manual
API route change	UT-API + RT-API	CI
Next.js config change	Build verification + RT-DEPLOY	CI

3.2 Test Suites

RT-AUTH — Authentication Regression

ID	Scenario	Precondition	Steps	Expected	Result
RT-AUTH-001	Login flow end-to-end	User is logged out	1. Navigate to /login 2. Enter valid credentials 3. Click Sign In	Redirected to / dashboard; sidebar visible	Not Run
RT-AUTH-002	Logout flow end-to-end	User is logged in	1. Click logout icon in sidebar 2. Observe redirect	Redirected to /login; / dashboard no longer accessible	Not Run
RT-AUTH-003	Direct URL access while unauthenticated	No gati_auth in localStorage	1. Navigate directly to / dashboard/ vehicles	Redirected to /login	Not Run

RT-AUTH-004	Session persists across page refresh	User is logged in	1. Reload the browser 2. Navigate to / dashboard	Dashboard loads without redirect	Not Run
-------------	--------------------------------------	-------------------	---	----------------------------------	---------

RT-NAV — Navigation & Routing

ID	Scenario	Steps	Expected	Result
RT-NAV-001	Sidebar links navigate correctly	Click each sidebar item	Each page loads with correct title and subtitle	Not Run
RT-NAV-002	Quick Add navigates to correct page	Click Add New → Add Vehicle	Navigated to / dashboard/ vehicles	Not Run
RT-NAV-003	Root URL redirects to login	Navigate to yadukrishnan117.github.io/studio/	Redirected to /studio/login	Not Run
RT-NAV-004	Mobile menu opens and navigates	Viewport < 1024px; click hamburger; click nav item	Sheet opens; page changes; sheet closes	Not Run

RT-ASSET — Asset CRUD Regression

ID	Scenario	Steps	Expected	Result
RT-ASSET-001	Asset list loads with data	Navigate to / dashboard/ assets	Table shows ≥1 asset row	Not Run
RT-ASSET-002	Search filters in real-time	Type 'lift' in search box	Table filtered to matching assets only	Not Run
RT-ASSET-003	Add asset form completes successfully	Fill all required fields; click Add Asset	New row appears at top of table	Not Run
RT-ASSET-004	Delete asset removes row	Click ⋮ → Delete → OK in confirm	Row removed from table	Not Run
RT-ASSET-005	Asset detail modal opens and closes	Click on an asset row	Modal with asset details opens; X closes it	Not Run

RT-NOTIF — Notifications Regression

ID	Scenario	Steps	Expected	Result
RT-NOTIF-001	Badge shows unread count on load	Load dashboard	Bell icon shows red badge with count	Not Run
RT-NOTIF-002	Clicking notification marks read	Open bell menu; click a notification	Blue dot disappears; badge count decrements	Not Run
RT-NOTIF-003	Mark all read clears badge	Click 'Mark all read'	Badge disappears	Not Run

RT-SETTINGS — Settings Regression

ID	Scenario	Steps	Expected	Result
RT-SET-001	User toggle changes isActive	Toggle switch for any user	Switch flips; no JS error	Not Run
RT-SET-002	Add user dialog opens and submits	Click Add User; fill form; click Add User	New user row appears in table	Not Run
RT-SET-003	Delete user with confirmation	Click Trash for a user; confirm	User removed from table	Not Run

RT-DEPLOY — Deployment / Build Regression

ID	Scenario	Steps	Expected	Result
RT-DEP-001	npm run build produces no errors	Run npm run build	Exit code 0; out/ directory created	Pass
RT-DEP-002	All pages statically exported	Check out/ after build	index.html, login/, dashboard/* all present	Pass
RT-DEP-003	GitHub Actions deploy workflow succeeds	Push to main; observe Actions tab	Build + Deploy jobs both green	Not Run
RT-DEP-004	Live URL responds with 200	curl https://yadukrishnan117.github.io/studio/	HTTP 200; <title>Gati-Tech AMS	Not Run

3.3 Regression Matrix — Feature vs Change Area

Auth

Test Suite \ Change Area		Sidebar/ TopNav	Assets Page	Settings Page	API Routes	Build/ Config
RT-AUTH	✓ Run	✓ Run	—	—	—	✓ Run
RT-NAV	—	✓ Run	—	—	—	✓ Run
RT-ASSET	—	—	✓ Run	—	✓ Run	—
RT-NOTIF	—	✓ Run	—	—	—	—
RT-SETTINGS	✓ Run	—	—	✓ Run	—	—
RT-DEPLOY	—	—	—	—	—	✓ Run

3.4 Execution Results

Suite	Total Cases	Passed	Failed	Blocked	Not Run
RT-AUTH	4	—	—	—	4
RT-NAV	4	—	—	—	4
RT-ASSET	5	—	—	—	5
RT-NOTIF	3	—	—	—	3
RT-SETTINGS	3	—	—	—	3
RT-DEPLOY	4	2	0	0	2
Total	23	2	0	0	21

4. Sign-off

Role	Name	Signature	Date	Decision
Developer				Approved v
QA Lead				
Security Reviewer				
Product Manager				

Release Criteria (must all be met before production go-live):

- All Critical and High VAPT findings remediated (V-001 through V-005)
- All RT-AUTH and RT-DEPLOY regression tests passing
- Unit test coverage $\geq$ 80% on auth and asset modules
- No open P1 bugs in the issue tracker